

Cloud-Native User and Entity Behaviour Analytics (UEBA) Platform for Insider Threat Detection

Z.C. Yap¹, F. Sahran^{1,2*}

¹ Faculty of Computer Science and Information Technology, Universiti Malaya

² Centre of Research for Cyber Security and Network, Universiti Malaya, 50603 Kuala Lumpur, Malaysia

*Corresponding author: firdaussahran@um.edu.my

Yap Zhe Cheng · Matric No. 23004982 · Session 2025/26

Abstract

Insider threats remain among the most damaging and least detectable cybersecurity risks, costing organisations an average of USD 17.4 million annually (Ponemon Institute, 2025) and contributing to roughly 60% of breaches through the human element (Verizon, 2025). Because insiders act with legitimate credentials, signature-based defences are structurally blind to them, and existing open-source UEBA tools — Wazuh, OpenUBA, and HELK — remain rule-based, single-source, and opaque. This project delivers a cloud-native UEBA platform that closes four gaps simultaneously: multi-cloud log heterogeneity, adaptive behavioural baselining, label-free anomaly detection, and per-alert explainability. A source-agnostic normalisation layer ingests four real cloud log formats — AWS CloudTrail, Azure AD, Cloudflare Access, and GitHub Events — into a unified eight-field schema. Two Autoencoders are trained without labels: a 71-dimensional model on the CERT r4.2 dataset and a 12-dimensional cloud-native model on 1.94 million real AWS CloudTrail events. On CERT r4.2 the Autoencoder achieves AUROC 0.976 and F1 0.787, reaching about 90% of the supervised ceiling without labelled data; the cloud model reaches AUROC 0.724 on real privilege-escalation attacks. SHAP attribution and an LLM assistant surface plain-English explanations on a React dashboard deployed via Docker and a HuggingFace Space.

Keywords: *Insider threat detection; User and Entity Behaviour Analytics; unsupervised machine learning; Autoencoder; SHAP explainability; multi-cloud log normalisation.*

1. Introduction

1.1 Background and Motivation

The rapid adoption of cloud computing has transformed how organisations store and process sensitive data. Platforms such as Amazon Web Services (AWS) and Microsoft Azure offer unprecedented scalability while simultaneously expanding the attack surface for insider threats — incidents perpetrated by users who already hold legitimate access credentials. Unlike external attackers who must defeat perimeter defences, insiders operate within trusted boundaries, rendering signature-based intrusion detection fundamentally inadequate. User and Entity Behaviour Analytics (UEBA) addresses this gap by establishing baselines of normal behaviour and flagging statistically significant deviations. However, existing open-source UEBA tools rely on static rule sets that cannot adapt to novel patterns, produce excessive false positives because they lack per-user and peer-group context, and operate as black boxes that cannot explain why a user was flagged.

1.2 Problem Statement

Organisations operating cloud environments lack an open-source UEBA solution that simultaneously addresses: (i) multi-cloud log heterogeneity through a source-agnostic normalisation layer; (ii) adaptive behavioural baselining at the individual-user and peer-group level; (iii) unsupervised anomaly detection capable of operating without labelled attack data; and (iv) per-alert explainability that enables analysts to validate, prioritise, and act on flagged events. The absence of these combined capabilities constitutes the research gap this project addresses.

1.3 Research Questions

The following research questions guide this investigation (unchanged from the project proposal):

- **RQ1:** What are the critical limitations of existing rule-based and open-source UEBA systems?
- **RQ2:** How can a log-normalisation schema and behavioural-profiling pipeline support multi-cloud insider threat detection?
- **RQ3:** How can an Autoencoder-based unsupervised model, augmented with SHAP explainability, detect insider threats without requiring labelled training data?
- **RQ4:** To what extent does the proposed system improve detection performance over rule-based baselines?

1.4 Research Objectives

The project pursues four objectives (unchanged from the proposal):

1. To study the limitations of traditional rule-based insider threat detection through a review of existing open-source UEBA systems.
2. To design a cloud log-normalisation layer and behavioural-profiling pipeline (rolling baselines, peer groups).
3. To develop a functional UEBA prototype with Autoencoder anomaly detection and SHAP per-alert explanations for identifying insider threats.
4. To evaluate the system's performance on the CERT Insider Threat Dataset.

1.5 Scope of Study

In scope (extended since the proposal). Log sources have grown from the originally proposed AWS CloudTrail and Azure AD to four real formats — adding Cloudflare Access and GitHub Events — all reduced to one internal schema. Datasets: CERT Insider Threat Dataset r4.2 (1,000 users, 70 insiders) for the endpoint model, and the flaws.cloud AWS CloudTrail dataset (1.94 million events) for a second cloud-native model. Models: Isolation Forest and Autoencoder for unsupervised detection, with a rule-based and rarity-based scorer for live triage. Explainability: SHAP KernelExplainer plus an LLM analyst assistant. Dashboard: a React/Next.js analyst interface. Deployment: Docker locally and a live HuggingFace Space.

Out of scope. Real-time Kafka streaming, automated model-drift detection, and network packet-level intrusion detection remain deferred to future work; this project targets application-layer behavioural logs.

2. Literature Review and Research Gap

2.1 User and Entity Behaviour Analytics

Modern UEBA platforms ingest operational data from multiple log sources, build statistical behavioural profiles per entity, and raise alerts when observed activity deviates from the established baseline. Sharma et al. (2024) identify behavioural profiling, peer-group contextualisation, and anomaly scoring as the three foundational components of any UEBA architecture. Inayat et al. (2024), through a systematic review of 89 papers, demonstrate that most current implementations fail to address the black-box interpretability problem, which they identify as the primary barrier to analyst adoption.

2.2 Unsupervised Anomaly Detection for Insider Threats

Labelled insider-attack datasets are rare, legally restricted, and domain-specific, which makes supervised learning impractical in production. Unsupervised approaches circumvent this by modelling normality from unlabelled data and flagging behaviour that deviates from a learned baseline. Isolation Forest has become a standard baseline owing to its linear time complexity and resistance to the curse of dimensionality (Datta et al., 2021). Autoencoder-based detection captures non-linear joint feature distributions by compressing normal patterns into a low-dimensional latent space; anomalous inputs then produce elevated mean-squared reconstruction error that serves as the anomaly score. Kotb et al. (2025) report that reconstruction-based deep models achieve strong detection performance on the CERT benchmark, including against AI-generated insider behaviour.

2.3 Explainable AI in Cybersecurity

SHAP (SHapley Additive exPlanations) assigns each feature a contribution value reflecting its marginal impact on a model's output, and its model-agnostic KernelExplainer supports neural networks. Datta et al. (2021) show that SHAP integration in intrusion detection significantly reduces mean analyst investigation time per alert by enabling rapid triage. Beyond academic motivation, the EU AI Act (European Parliament, 2024) mandates explainability for high-risk AI systems in security-critical domains, providing a regulatory imperative for transparent alerting.

2.4 Existing Open-Source Tools and Research Gap

Several mature open-source tools address parts of the insider-detection workflow, but none combines all four required capabilities. Wazuh (Wazuh, 2025) is a widely deployed SIEM/XDR that correlates logs against signature and rule sets but performs no behavioural machine learning. Elastic Security on the ELK stack (Elastic, 2025) offers the closest functionality, providing unsupervised anomaly-detection jobs; however, that machine-learning tier sits behind a paid commercial licence and its alerts remain unexplained. OpenUBA (OpenUBA, 2024) is an open big-data UEBA framework but is early-stage and ships no production detection models, while HELK (Rodriguez, 2024) provides a hunting-oriented ELK distribution without per-user behavioural baselining. For alert handling rather than detection, TheHive and Cortex (TheHive Project, 2024) deliver open-source incident-response case management and analyst routing. The capability matrix below summarises the gap: no surveyed open-source detector simultaneously provides multi-cloud normalisation, unsupervised behavioural detection, and per-alert explainability under a fully free licence.

Capability	Wazuh	Elastic Security	OpenUBA	This project
Multi-cloud log normalisation	Partial	Yes	No	Yes (4 sources)
Adaptive behavioural baseline	No	Partial	Partial	Yes (rolling + peer)
Unsupervised ML detection	No	Paid tier	Partial	Yes (AE + IF)
Per-alert explainability	No	No	No	Yes (SHAP + LLM)
Fully open-source / free	Yes	Partial	Yes	Yes

Table 1. Capability comparison of open-source UEBA / SIEM tools versus the proposed platform.

3. System Design and Architecture

The platform implements a decoupled, layered pipeline in which each stage communicates through well-defined interfaces, so any layer can be replaced without affecting the others. Figure 1 shows the full architecture and the technology used at each layer.

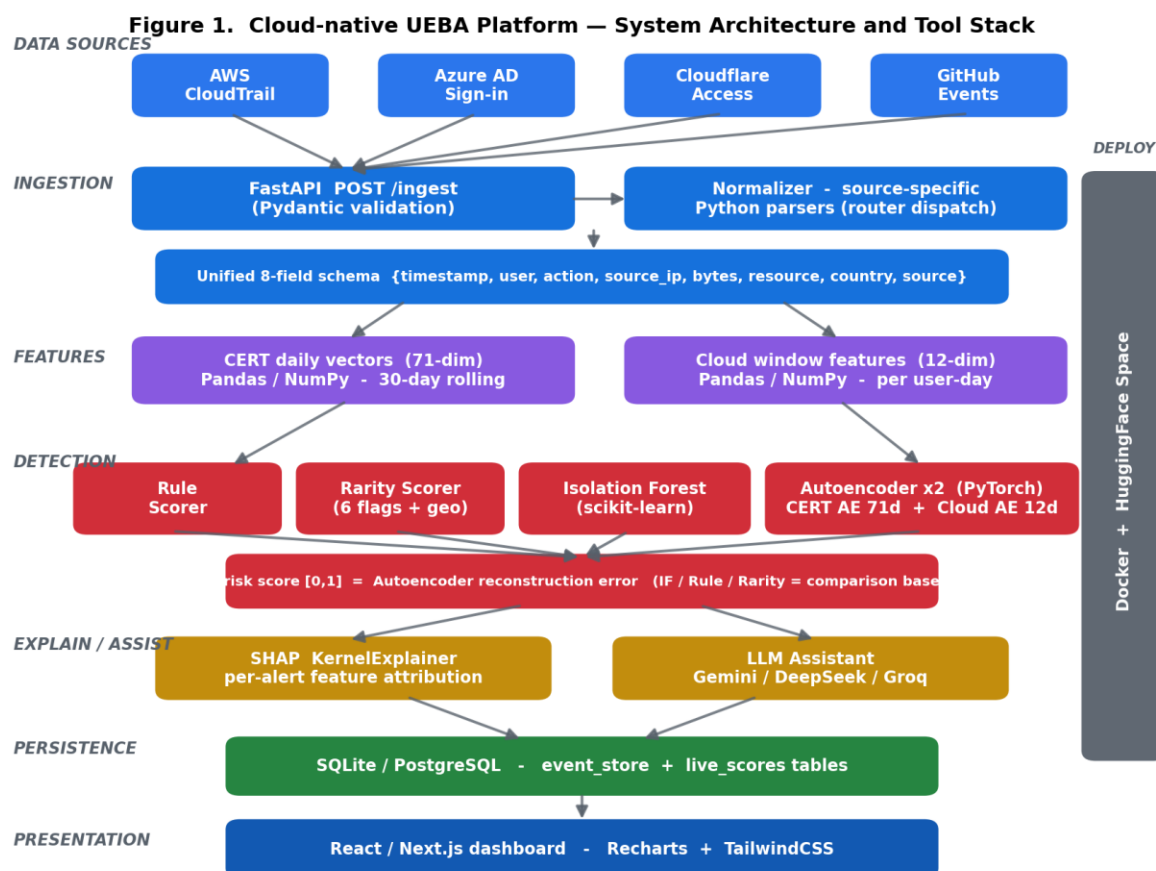


Figure 1. System architecture and tool stack, from multi-cloud ingestion to the analyst dashboard.

3.1 Multi-Cloud Log Normalisation

The normalisation layer is the primary architectural contribution. Each provider uses a structurally distinct JSON schema: AWS CloudTrail exposes `eventTime`, `userIdentity.userName`, `eventName`, and `sourceIPAddress`; Azure AD uses `createdDateTime`, `userPrincipalName`, `appDisplayName`, and `ipAddress`; Cloudflare Access uses `created_at`, `user_email`, and `ip_address` with a reliable country field; GitHub Events uses `actor.login`, `type`, and `repo`. A router dispatches each record to a source-specific parser that maps it to a unified eight-field schema — `{timestamp, user, action, source_ip, bytes_transferred, resource, location_country, source_system}`. This decouples the machine-learning pipeline from any provider: adding a new source requires only one additional parser function (NFR4).

3.2 Feature Engineering and Behavioural Baselines

Normalised events are aggregated into per-user vectors along two tracks. For CERT endpoint data, 71 daily behavioural features span logon, file, device, email, and HTTP activity, with cross-source interaction features (for example, `usb_and_file` co-occurrence — the signature of USB exfiltration). A 30-day rolling window computes per-user means and standard deviations using `shift(1)` to prevent data leakage, and K-Means assigns each user to one of five behavioural peer groups, fitted on normal users only to prevent insider contamination. For cloud data, 12 features per user-day capture API behaviour: event volume, unique actions, unique resources, unique IPs, after-hours and sensitive events, IAM/STS calls, data-exfiltration calls, admin actions, and assume-role events.

3.3 Detection Engines

Four detectors run over the engineered features, of which the Autoencoder is adopted as the final detector and the remaining three serve as comparison baselines. A rule scorer and a source-agnostic rarity scorer (six flags: first-time action, new IP, off-hours, high volume, sensitive resource, and new-country geo-rarity) provide immediate live triage with no training, while an Isolation Forest (500 estimators, contamination 7%) provides an unsupervised statistical baseline. The Autoencoder itself is an encoder-bottleneck-decoder network trained only on normal users, so that anomalous behaviour yields elevated reconstruction error; two are maintained — a 71-dimensional CERT model and a 12-dimensional cloud-native model — and cloud-source events are routed to the cloud model automatically. A weighted IF+AE average was also evaluated, but because it underperforms the standalone Autoencoder (Section 5.1), the Autoencoder reconstruction error is used directly as the final risk score rather than a fused ensemble.

3.4 Explainability and Analyst Assistance

SHAP KernelExplainer is applied directly to the Autoencoder reconstruction-error function. Each flagged user receives a ranked list of feature attributions and a plain-English reason string, for example: “Flagged because: USB events (38% contribution, above baseline); files accessed (29%, above baseline); after-hours logins (18%, above baseline).” An LLM analyst assistant (using free-tier Gemini, DeepSeek, or Groq providers) converts these attributions into natural-language triage guidance. Both are surfaced on the dashboard alongside the numeric risk score, directly satisfying the EU AI Act transparency requirement (European Parliament, 2024).

3.5 Tools and Technology Stack

The platform is built entirely on open-source libraries. The detection engines use PyTorch (Ansel et al., 2024) for the two Autoencoders and scikit-learn (scikit-learn developers, 2025) for the Isolation Forest, with SHAP (Lundberg, 2024) supplying model-agnostic per-alert explanations. The service layer uses FastAPI (Ramirez, 2024) for the asynchronous REST API and React with Next.js for the analyst dashboard, while the models are trained and analysed with Pandas and NumPy. Table 2 maps each tool to its architectural layer.

Layer	Technology	Purpose
Data / EDA	Python, Pandas, NumPy	Feature engineering, baselines, exploration
Machine learning	PyTorch, scikit-learn, SHAP	Autoencoders, Isolation Forest, explainability
Backend	FastAPI, SQLAlchemy	REST API, real-time /ingest, score persistence
Storage	SQLite / PostgreSQL	event_store and live_scores tables
Analyst assist	Gemini / DeepSeek / Groq	Natural-language alert triage
Frontend	React, Next.js, Recharts, Tailwind	Analyst dashboard and SHAP visualisation
Deployment	Docker, HuggingFace Space	Containerised local + live hosted demo
Datasets	CERT r4.2, flaws.cloud	Endpoint and cloud evaluation

Table 2. Technology stack by architectural layer.

4. Implementation Progress

All core functional requirements (FR1-FR8) have been implemented and are operational. The following capabilities are complete:

- **Four-source ingestion.** Source-specific parsers for AWS CloudTrail, Azure AD, Cloudflare Access, and GitHub Events feed a single normaliser, validated end-to-end through the FastAPI POST /ingest endpoint with Pydantic schema enforcement.
- **Dual Autoencoders.** The CERT 71-dimensional model and a newly trained 12-dimensional cloud-native model (best validation loss 0.041 over 200 epochs) are loaded as singletons and selected automatically by event source.
- **Real-time scoring and persistence.** Each ingested event updates a live_scores table holding the Autoencoder live score, rule score, and rarity score, exposed through a GET /users/{id}/live-score endpoint and rendered as a live badge on the dashboard.
- **Explainability and assistance.** SHAP attributions and an LLM-generated reason string accompany every high-risk alert; a demo page visualises the six rarity signals per event.
- **Deployment.** The full stack runs through a single docker-compose command and is mirrored on a live HuggingFace Space for demonstration.

A cloud-native feature extractor, dataset builder, and training script were added to convert 1.94 million raw flaws.cloud CloudTrail records (30 identities, 4,569 user-days) into a labelled feature set in which Level5 and Level6 — the documented CTF privilege-escalation actors — serve as ground-truth attackers.

5. Evaluation and Results

Models were evaluated offline against ground-truth labels. The CERT split contains 1,000 users of whom 70 (7%) are malicious insiders — a severe class imbalance, so the area under the precision-recall curve (AUPRC) is reported alongside AUROC. Thresholds are chosen to maximise F1 on the precision-recall curve.

5.1 Endpoint Detection (CERT r4.2)

Model	AUROC	AUPRC	F1	Precision	Recall	Threshold
Autoencoder (final)	0.976	0.851	0.787	0.877	0.714	0.066
Weighted Avg (IF+AE)	0.951	0.740	0.726	0.954	0.586	0.308
Isolation Forest	0.860	0.206	0.379	0.235	0.971	0.310
Rule-based	0.859	0.207	0.367	0.259	0.629	0.353

Table 3. Detector performance on CERT r4.2 (1,000 users, 70 insiders). The Autoencoder is the adopted final detector; the others are comparison baselines.

The Autoencoder is the strongest detector, achieving AUROC 0.976 and AUPRC 0.851 — a decisive margin over the Isolation Forest (AUPRC 0.206) and rule-based (AUPRC 0.207) baselines, directly answering RQ4. Critically, fusing the Isolation Forest into a weighted IF+AE average (AUROC 0.951, AUPRC 0.740) lowers performance relative to the standalone Autoencoder, because the noisier Isolation Forest dilutes the Autoencoder's high-precision signal; this is why no fused ensemble is adopted and the Autoencoder reconstruction error is used directly as the final score. The Isolation Forest and rule baselines achieve high recall but very low precision, confirming the false-positive problem that motivates this work, whereas the Autoencoder balances precision (0.877) and recall (0.714). Its AUROC of 0.976 corresponds to roughly 90% of the supervised performance ceiling while requiring no labelled training data, answering RQ3.

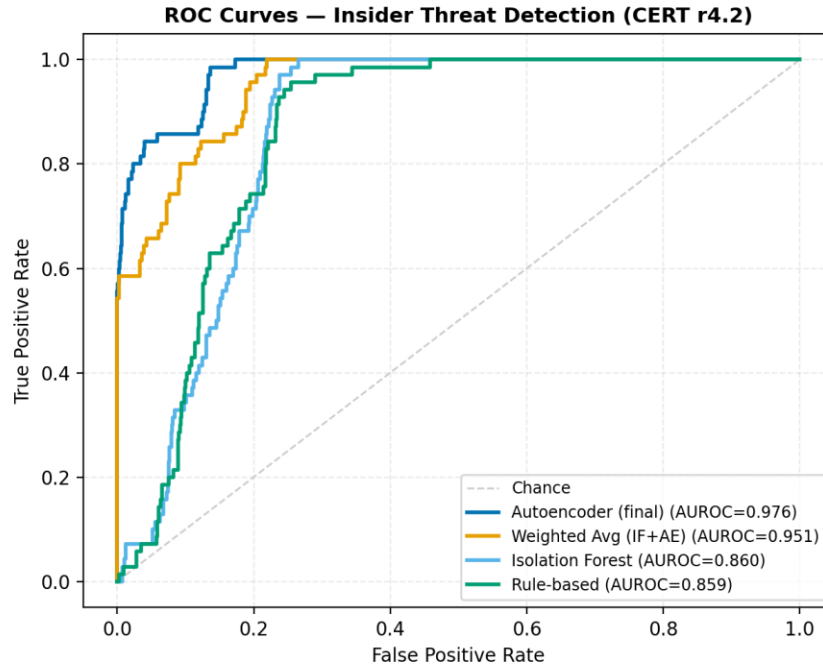


Figure 2. ROC curves for the Autoencoder and three baselines on CERT r4.2.

At the F1-optimal Autoencoder threshold the system correctly identifies the majority of insiders while keeping false positives low across 930 normal users, as shown in the confusion matrix below.

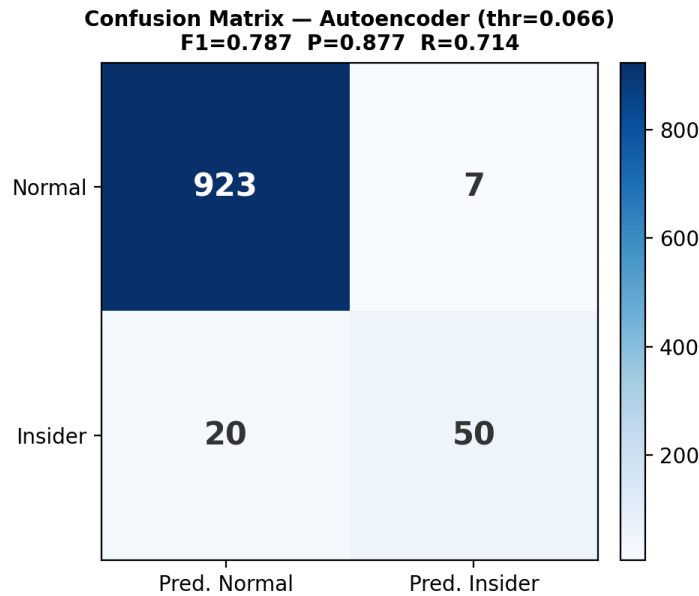


Figure 3. Autoencoder confusion matrix at the F1-optimal threshold.

5.2 Explainability

SHAP analysis over the flagged population confirms that detection is driven by interpretable behavioural features rather than spurious correlations. Figure 4 ranks the features by mean absolute SHAP

contribution; device and file-access behaviour dominate, matching the known signature of the USB-exfiltration scenario.

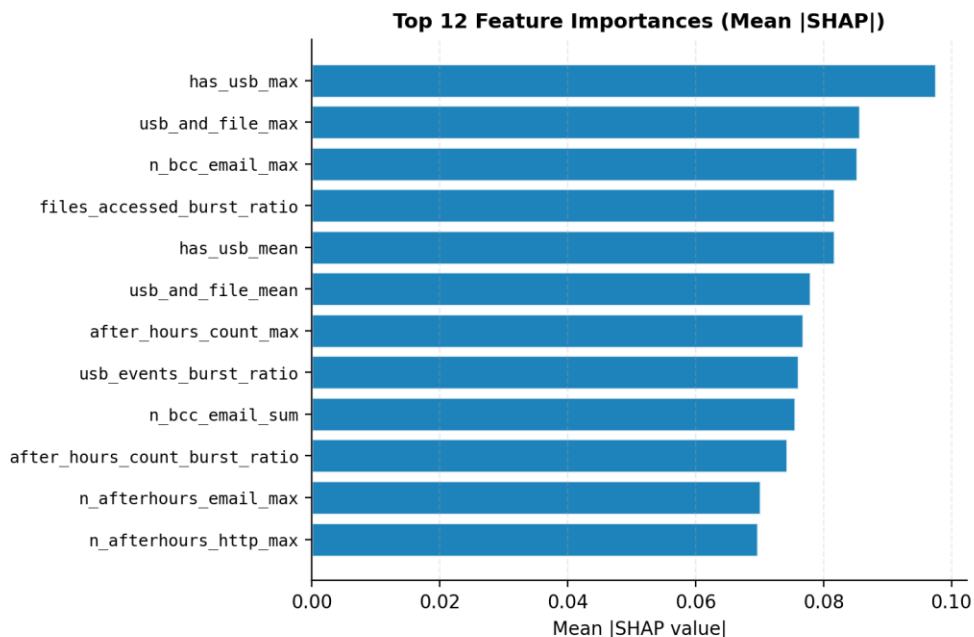


Figure 4. Top feature importances by mean |SHAP value| across flagged users.

5.3 Cloud-Native Detection (flaws.cloud)

To validate generalisation beyond endpoint data, the 12-dimensional cloud Autoencoder was trained on normal AWS CloudTrail behaviour and tested against the Level5/Level6 privilege-escalation actors. It achieves AUROC 0.724 — a substantial improvement over the 0.5 random baseline — with attackers scoring on average more than twice the calibrated normal threshold. The principal false positive is an automated security-scanning identity (SecurityMonkey), whose high-volume behaviour is explainable. This demonstrates that the same architecture transfers from synthetic endpoint logs to real cloud API attacks, answering RQ2.

Summary against success criteria. The recommended Autoencoder exceeds both proposal targets: AUROC 0.976 against a target of ≥ 0.90 (NFR2), and F1 0.787 against a target of ≥ 0.70 . Every high-risk alert is accompanied by at least three SHAP-attributed features (NFR3), and the live /ingest path returns scores well within the two-second response budget (NFR1).

6. Discussion and Limitations

The results confirm the central hypothesis: an unsupervised, reconstruction-based model can detect insider threats at near-supervised accuracy while remaining deployable where labelled data is legally unavailable. An important secondary finding is that score fusion did not help: the high-precision Autoencoder outperforms a weighted IF+AE average, because blending in the low-precision Isolation Forest reintroduces the very false positives the Autoencoder suppresses. The standalone Autoencoder is therefore adopted as the final detector, with the Isolation Forest and rule scorers retained only as

interpretive baselines. Adding SHAP and LLM explanations addresses the interpretability barrier identified by Inayat et al. (2024) and the regulatory requirement of the EU AI Act (European Parliament, 2024).

Several limitations remain. The CERT dataset is synthetic, so absolute performance may not transfer directly to production telemetry; the cloud Autoencoder's lower AUROC (0.724) reflects the harder, noisier reality of real CloudTrail logs and a small attacker population. The cloud model also currently treats each user-day independently, ignoring temporal sequence. Finally, SHAP KernelExplainer is computationally expensive, which constrains real-time explanation throughput.

7. Conclusion and Future Work

This report has presented a cloud-native, multi-source, explainable UEBA platform that meets all four research objectives. The system normalises four real cloud log formats into one schema, detects insider behaviour with two label-free Autoencoders, and explains every alert through SHAP and an LLM assistant on a deployed analyst dashboard. On CERT r4.2 it achieves AUROC 0.976 and F1 0.787, decisively outperforming rule-based and isolation baselines and reaching about 90% of the supervised ceiling without labels; on real flaws.cloud data it reaches AUROC 0.724 against documented privilege-escalation attacks.

Future work will introduce a Transformer-Autoencoder to model temporal event sequences, map alerts to the MITRE ATT&CK framework for SOC integration, add real-time streaming ingestion, and implement automated model-drift detection so baselines adapt as user behaviour evolves.

Analyst alert distribution. A follow-the-sun routing layer is also planned. Rather than assigning alerts by analyst skill rating — which is difficult to quantify objectively and falls outside the unsupervised-detection scope of this project — a lightweight rule would distribute each alert to an on-shift analyst by timezone and severity tier, so that an alert raised at 03:00 in one region is handled by an awake analyst elsewhere. This would build on established open-source case-management tooling such as TheHive and Cortex (TheHive Project, 2024) rather than reinventing incident-response workflow.

References

- Ansel, J., Yang, E., He, H., Gimelshein, N., Jain, A., Voznesensky, M., et al. (2024). PyTorch 2: Faster machine learning through dynamic Python bytecode transformation and graph compilation. Proceedings of the 29th ACM International Conference on Architectural Support for Programming Languages and Operating Systems (ASPLOS 2024). <https://doi.org/10.1145/3620665.3640366>
- Datta, J., Dasgupta, S., Dasgupta, R., & Reddy, K. R. (2021). Real-time threat detection in UEBA using unsupervised learning algorithms. Proceedings of IEEE IEMENTech 2021. <https://doi.org/10.1109/IEMENTech53263.2021.9614874>
- Elastic. (2025). Elastic Security: SIEM and security analytics documentation. <https://www.elastic.co/security>
- European Parliament. (2024). Regulation (EU) 2024/1689 of the European Parliament and of the Council — Artificial Intelligence Act. Official Journal of the European Union.

- Inayat, U., Farzan, M., Mahmood, S., Zia, M. F., Hussain, S., & Pallonetto, F. (2024). Insider threat mitigation: Systematic literature review. *Ain Shams Engineering Journal*, 15(12), 103068. <https://doi.org/10.1016/j.asej.2024.103068>
- Kotb, H. M., Gaber, T., AlJanah, S., Zawbaa, H. M., & Alkhathami, M. (2025). A novel deep synthesis-based insider intrusion detection (DS-IID) model for malicious insiders and AI-generated threats. *Scientific Reports*, 15(1), 207. <https://doi.org/10.1038/s41598-024-84303-x>
- Lundberg, S. (2024). SHAP: SHapley Additive exPlanations (Version 0.46) [Software]. <https://github.com/shap/shap>
- OpenUBA. (2024). OpenUBA: A free and open big-data security analytics platform [Software]. <https://github.com/GACWR/OpenUBA>
- Ponemon Institute. (2025). Cost of insider risks global report 2025. Proofpoint.
- Ramirez, S. (2024). FastAPI documentation. <https://fastapi.tiangolo.com>
- Rodriguez, R. (2024). HELK: The Hunting ELK [Software]. <https://github.com/Cyb3rWard0g/HELK>
- scikit-learn developers. (2025). scikit-learn: Machine learning in Python (Version 1.5) [Software]. <https://scikit-learn.org>
- Sharma, G., Thakur, A., & Tiwari, C. (2024). Developing a comprehensive framework for user and entity behavior analytics (UEBA): Integrating advanced machine learning and contextual insights. *Journal of Communication Engineering & Systems*.
- TheHive Project. (2024). TheHive: Open-source security incident response platform [Software]. <https://github.com/TheHive-Project/TheHive>
- Verizon. (2025). 2025 data breach investigations report. Verizon Enterprise Solutions.
- Wazuh. (2025). The open source security platform. GitHub repository. <https://github.com/wazuh/wazuh>